
TROPIC01

ODR_TR01_SA_2026012900

Potential Bypass of Firmware Verification by Laser Fault Injection

Version: 1.0

Abstract

This Security Advisory (SA) provides comprehensive information about Potential Bypass of Firmware Verification by Laser Fault Injection in the TROPIC01.

June 3, 2026





Vulnerability Type	CWE-1332: Improper Handling of Faults that Lead to Instruction Skips
Impact	Information Disclosure
Severity	MEDIUM 5.7 (CVSS Version 3.1)
Attack Type	Physical/Laser Fault injection (LFI)
Attack Vector	Laser Fault Injection targeting the signature verification procedure may cause a verification skip allowing an attacker to load and execute an arbitrary application FW into TROPIC01.
Affected Products	All TROPIC01 production part numbers – see the Affected Products section.
Disclosure Date	2026-06-03
Contact	Tropic Square Security Team <security@tropicsquare.com>

Notice

Tropic Square is committed to delivering accurate information about confirmed security flaws in its products to its customers in a public manner.

The public Security Advisory (SA) provides information about a medium- or high-impact vulnerability confirmed in our product along with its detailed description. This information enables our customers to take proactive, informed action to mitigate vulnerability exploitation in related products. A preliminary, confidential SA was delivered to Tropic Square customers in advance to allow proactive, informed actions to mitigate vulnerability exploitation, in line with our [Coordinated Vulnerability Disclosure policy](#).

Who Is This Advisory Intended For?

This Security Advisory is intended for Tropic Square partner security contacts, as well as for security researchers and security experts in the general public.



Executive Summary

Vulnerability disclosed (<https://www.tropicsquare.com/cvd>) to Tropic Square on 2026-01-27 describes a powerful, yet challenging and costly attack that allows booting of adversary FW in the TROPIC01 secure element. The booted FW is non-persistent, thus it cannot be booted inside the user application-but the modified/preprocessed chip must be present in the lab while the lab equipment manipulates the boot process during boot. All TROPIC01 units based on the current silicon architecture are affected – see the [Affected Products](#) section. **All confidential data in TROPIC01 might be compromised by a challenging combined attack** enabled by the reported vulnerability.

To exploit the vulnerability, **full physical access to the TROPIC01 device is needed**. Desoldering and decapsulation of the chip must be performed. Expert-level attacker knowledge and costly specialized equipment are needed.

The **cost of ownership** for the laboratory setup **needed to exploit the reported vulnerability** is assessed to be **higher than 30,000 Euro**. The highly advanced skillset is required to perform the attack. The estimated time needed for vulnerability identification and exploitation for an expert-level attacker is 3 – 4 weeks.

The end application threat model knowledge is critical for assessing the overall risk of the vulnerability to the end application.

Tropic Square recommends measures to mitigate the potential attack in current products presented in this Security Advisory (SA).

A silicon update to mitigate the attack in future TROPIC01 product revisions is in development. Please, contact us for more information about product availability updates:

- <https://tropicsquare.com/contact-us>
- support@tropicsquare.com

Version History

Version	Date	Description
1.0	03.6.2026	Initial Public SA Version



Affected Products

Part Number (P/N)	Bootloader version	Application FW version	SPECT FW version	Note
TROPIC01-ES	1.0.1			Engineering samples, sensors are disabled.
TR01-B2S-T005	1.0.1	0.2.0	0.3.1	Sensors are disabled.
TR01-C2P-T101	2.0.1	0.3.1	0.3.1	Sensors are enabled ¹ .
TR01-C2P-T103	2.0.1	0.3.1	0.3.1	Sensors are enabled ¹ .
TR01-C2P-T202	2.0.1	0.5.0	0.3.1	Sensors are enabled ¹ .
TR01-C2P-T301	2.0.1	1.0.0	1.0.0	Sensors are enabled ¹ .
TR01-C2P-T310	2.0.1	2.0.0	1.0.0	Sensors are enabled ¹ .

See [2] for details.

¹Bit-Flip Detectors, EM-Pulse, Glitch Detectors, Laser Detectors, Oscillator Monitor, TRNG Entropy Test, Temperature Sensor, Shield.



Vulnerability Summary

Date Reported	2026-01-27
Reporter	Donjon @ Ledger
CVD Report ID	TR01_CVD_2026012900
Public Vulnerability ID	–
Attack Vector Severity	Low – full physical access to TROPIC01 device needed, expert knowledge, and advanced/specialized equipment needed.
Affected Assets	All confidential data in TROPIC01 can be potentially compromised directly or by employing a combined attack enabled by the reported vulnerability. 1. ECC keys 2. User data stored in non-volatile memory 3. MAC-and-Destroy keys and slot contents
Overall Risk	Medium risk – complex and costly attack utilizing expensive equipment, but an attacker can run unauthorized firmware on the chip and hence gain full access to the chip in case of success. Estimated cost of the equipment ownership is 30,000 Euro. Estimated time needed for the vulnerability identification and exploitation for an expert-level attacker is 3 – 4 weeks.



Recommendations

Attack Avoidance	1. Monitoring of the physical security of devices with TROPIC01, and taking appropriate actions (depending on the nature of the application) to avoid the risk of vulnerability exploitation, because performing the practical attack requires significant effort and time.
Attack Identification Mitigation	1. The vulnerability information disclosure embargo for the reported vulnerability (under the CVD) until 2026-06-03. 2. The vulnerability information disclosure embargo for the MAC-and-Destroy attack vector until the first half of 2027.
Attack Exploitation Mitigation Current Devices	1. Maintenance Mode Restriction: Disabling maintenance mode prevents direct firmware uploads. An attacker must successfully bypass this system state before they can even attempt a firmware signature bypass. 2. Perform device FW updates in a secure/controlled environment only, and include all recommended actions: (a) Boot the application FW (b) Enable the maintenance mode (c) Reboot to the maintenance mode (d) Update FW in both flash banks (e) Boot the application FW (f) Disable maintenance mode The recommended FW update procedure [4] is implemented in libtropic-v4.0.0 <i>Note: The recommended mitigation settings add an additional layer of protection, and increase the potential attack complexity.</i>



Attack Exploitation Mitigation	1. Attack points allowing exploitation of the reported vulnerability, as well as the potential MAC-and-Destroy attack vector enabled by this vulnerability were identified and LFI measures mitigating the attack vector as well as an architecture fix addressing the MAC-and-Destroy weakness were implemented for future devices.
Future Devices	The measures implemented in the bootloader and the silicon-level microarchitecture improve the robustness of the TROPIC01 chip, and will mitigate the exploitation of the vulnerability by the current attack vector in future products.



Vulnerability Insights

For the detailed assessment, we follow the method inspired by the Common Criteria certification assessment developed in the [ORSHIN research project](#). The following text concludes the detailed internal vulnerability assessment.

Attack Vector

The Laser Fault Injection targeting the signature verification procedure implemented in SPECT FW may cause a verification skip allowing to load and execute an arbitrary application FW into TROPIC01.

The attack is composed of two steps:

1. During the firmware update process, signature verification skip allows upload of the arbitrary FW to the on-chip flash memory – this needs to be successfully performed once to store an adversary firmware in the on-chip flash memory.
2. Consequently, the signature verification skip during the boot process is used to load the FW from the flash memory to RAM. This needs to be performed on each power up of the device.

Details about the boot process can be found in the ODN_TR01_app_007 app Note [4], Section 2.

Compromised Assets

1. ECC keys
2. User data stored in non-volatile memory
3. MAC-and-Destroy keys and slots content (attack vector not published)



Attacker Characteristics

Weakness Identification

Method	Required Experience	Description
Identification of the signature verification procedure from the power traces	Expert	Familiar with implemented algorithms, protocols, hardware structures, security behaviour, principles, concepts of security employed, techniques and tools for the definition of new attacks, cryptography, classical attacks for the product type, attack methods, etc.

Currently, **expert knowledge is required** for the weakness identification.

Specialized equipment and expert knowledge is required to perform weakness identification by analyzing power traces. The equipment includes tools and resources, requiring a kind of expertise: such as power analysis tools, protocol analyzers, or oscilloscopes.

Examples of such workplaces include a university microelectronics or electro-materials laboratory, (HW) certification or evaluation lab or a (HW) hacker space lab.

Costs for working in such a workplace could be negligible, but expert knowledge is still required.

Estimated time needed for the **weakness identification** for the **expert-level attacker is 2 weeks**.



Vulnerability Exploitation

Method	Required Experience/Equipment	Description
Chip Backside Decapsulation	Expert/Specialized	Tools and resources not easily accessible require a kind of expertise OR less expensive equipment for a more experienced attacker.
Laser Fault Injection (LFI)	Expert/Specialized Institute	Equipment not easily accessible to the general public, either requiring special production, being highly specialized with controlled distribution, or being prohibitively expensive.
Simpler/cheaper Fault Injection methods	Expert	Not feasible for TROPIC01 – based on the current evaluation results.

Expert knowledge is required for the chip decapsulation. It is possible to perform the decapsulation in the equipped workplace or buy it as a service. The estimated cost of the service is less than 1,000 Euro. More knowledgeable attackers might perform low-cost decapsulation; easy methods are known, but hands-on experience is required – only the back-side decapsulation is needed.

Expert knowledge, and highly specialized and costly equipment is required to execute the attack. The cost of the equipment limits its availability. The estimated **cost of ownership is more than 30,000 Euro** for a simplest setup.

Examples of such workplaces include a specialized HW security university or research institute laboratory, or the (HW) certification or evaluation lab.

A knowledgeable expert with significant hands-on experience is required to fine-tune the fault-injection process to overcome the sensor countermeasure in newer configurations of TROPIC01 – chips with the bootloader version 2.0.1.

Estimated time needed for the **vulnerability exploitation** for the **expert-level attacker** with full access to the equipment **is 2 weeks**.

Estimated time needed to repeat the attack on another chip/multiple chips will go down below 1 day/chip.



Timeline

2026-01-27	Vulnerability report received by Tropic Square from the external reporter.
2026-01-29	Vulnerability confirmed. Kick-off meeting with the vulnerability reporter.
2026-05-11	Internal confirmation of the MAC-and-Destroy vulnerability.
2026-06-03	Vulnerability disclosure date.
2026-Q4	Expected availability of hardened TROPIC01s (exact date will be announced).
2027-Q2	Planned MAC-and-Destroy attack vector disclosure (exact date will be announced).

References

- [1] ODD_TR01_datasheet, TROPIC01 Datasheet, Tropic Square,
<https://github.com/tropicsquare/tropic01/tree/main/doc/datasheet>
- [2] OD_TR01_catalog_list, TROPIC01 Catalog List, Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/catalog_list
- [3] ODN_TR01_app_002 – PIN Verification Application Note,
Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/application_notes
- [4] ODN_TR01_app_007 – FW Update Application Note,
Tropic Square,
https://github.com/tropicsquare/tropic01/tree/main/doc/application_notes



Legal Notice and Permitted Use

Scope: This report is issued by Tropic Square to inform the public about a security evaluation of a Tropic Square product, the general nature and potential impact of the findings, and any remediation or mitigation measures taken, where applicable. This notice applies to all information contained in or accompanying the report.

Permitted Use and Legal Compliance: This report, including any technical information it contains, is provided solely for security awareness, defensive validation, remediation, and authorized security testing. Readers are responsible for complying with all applicable laws, regulations, and contractual obligations, and must not use this report for any unauthorized, harmful, or unlawful purpose.

No Warranty and Liability Limitation: This report is provided on an “as is” basis. Tropic Square makes reasonable efforts to provide accurate and useful information but does not warrant that the report is complete, error-free, applicable to every environment, or sufficient to eliminate all security risks. This report also does not constitute a warranty regarding any product’s suitability for a particular purpose. To the maximum extent permitted by applicable law, Tropic Square shall not be liable for any damages, losses, claims, or disruptions arising from the use, misuse, inability to use, or reliance on this report.

Repository Consistency Disclaimer: Where this report refers to public repositories or published materials, readers should note that such materials may not always identically correspond to a specific product version, configuration, or release. Differences may arise due to publication timing, implementation details, hardware integration, third-party rights, or other technical or legal limitations. Any use, copying, modification, or redistribution of materials from Tropic Square repositories is governed by the applicable license terms in those repositories.

Intellectual Property: Nothing in this report grants any intellectual property right, except for a limited, non-exclusive, revocable permission to read, reference, quote, and share the report for lawful security awareness, risk assessment, and remediation purposes. Any sharing must preserve attribution to Tropic Square, must not be misleading, and must not present outdated versions as current. Redistribution is permitted only in complete and unmodified form, except for clearly identified quotations, references, or summaries that do not misrepresent the report.

Limited Disclosure of Detailed Findings: This public report may be based on one or more underlying evaluation reports. For security reasons, Tropic Square may omit,



redact, delay, generalize, or withhold detailed findings or other sensitive technical information where disclosure could increase risk to users, customers, partners, or other affected parties. Such information may be protected by confidentiality measures to reduce the risk of misuse.

Authorized Testing: Tropic Square encourages good-faith security research conducted in accordance with its [Coordinated Vulnerability Disclosure Policy \(CVD\)](#). Any reported weakness or vulnerability will be handled in accordance with that policy and may, where appropriate, form the basis of further public reports. Publication of this report does not authorize testing or other security research outside the scope of that policy.

Researcher Acknowledgement: Tropic Square may acknowledge researchers who contributed to relevant findings, subject to their consent. Any such acknowledgement does not imply employment, agency, endorsement, partnership, authorization to test outside the CVD Policy, or approval of any conduct not expressly permitted by that policy.

Updates: Tropic Square may update this report from time to time, and readers should verify that they are relying on the latest available version. Where this report conflicts with later Tropic Square advisories, errata, release notes, product documentation, or direct security communications, the later or more specific communication controls unless stated otherwise.

Contact: Questions regarding this report should be submitted through Tropic Square's official security contact channel: security@tropicsquare.com. Suspected vulnerabilities should be reported in accordance with the CVD Policy: <https://www.tropicsquare.com/cvd>.